S.E.P. TECNOLÓGICO NACIONAL DE MÉXICO

INSTITUTO TECNOLÓGICO de Tuxtepec

MATERIA:
AUDITORIA INFORMÁTICA

ALUMNO:
JOSÉ ÁNGEL AGUILAR BRAS
JUAN DE JESÚS BAUTISTA GARCÍA
JOSÉ DAVID JUÁREZ RASGADO
OLIVER SANTIAGO ISIDORO
IVAN DE JESÚS VICTORIANO ZARAGOZA

DOCENTE:
MCyTE. María de los Ángeles Martínez Morales

CARRERA:
INGENIERIA INFORMÁTICA

INGENIERÍA INFORMÁTICA

1) Plan de auditoria

1. DATOS GENERALES

Elemento	Información
Proceso a Auditar	Auditoría de Infraestructura tecnológica y comunicaciones de CompuMax
Sistema / Aplicación	Red local (LAN), red inalámbrica (WiFi), software administrativo y equipos de soporte técnico.
Área	Infraestructura Tecnológica y Soporte técnico
Líder del proceso	Encargado del área de TI
Equipo Auditor	José Ángel Aguilar Bras, Juan de Jesús Bautista García, José David Juárez Rasgado, Oliver Santiago Isidoro, Ivan de Jesús Victoriano Zaragoza
Auditor Líder	Juan de Jesús Bautista García

2. CONTEXTO DEL PROCESO

Pregunta guía	Respuesta
¿Cuál es la función crítica del activo o segmento de red en la operación?	Garantizar la disponibilidad de los servicios tecnológicos que permiten realizar ventas, gestionar inventarios, brindar soporte técnico y mantener la comunicación entre los equipos de trabajo.
¿Qué proceso empresarial depende directamente de esta infraestructura?	Los procesos de ventas, atención al cliente, administración de inventario, gestión administrativa y servicios de soporte técnico.

¿Qué niveles de confidencialidad o criticidad tienen los datos que transitan por estos medios?	Se manejan datos operativos y comerciales de importancia media y alta, incluyendo información de clientes, inventarios, ventas y documentación administrativa.
¿Qué procesos se detienen, qué activos se dañan o qué costos operativos implica una caída?	Una interrupción puede detener las ventas, afectar la atención al cliente, impedir el acceso a información administrativa y generar pérdidas económicas por inactividad operativa.
Equipo Auditor	José Ángel Aguilar Bras, Juan de Jesús Bautista García, José David Juárez Rasgado, Oliver Santiago Isidoro, Ivan de Jesús Victoriano Zaragoza
Auditor Líder	Juan de Jesús Bautista García

3. OBJETIVO DE LA AUDITORIA (Redactar con enfoque evaluativo.)

Evaluar el nivel de cumplimiento de la infraestructura de hardware, redes y telecomunicaciones de CompuMax respecto a estándares y buenas prácticas reconocidas, con el propósito de identificar riesgos operativos, vulnerabilidades de seguridad, deficiencias de control y oportunidades de mejora que contribuyan a la continuidad y eficiencia de los servicios tecnológicos.

Específico

Hardware

- Evaluar el estado físico, inventario, mantenimiento y condiciones de operación de los equipos de cómputo, impresoras y dispositivos tecnológicos utilizados por CompuMax.

Redes

- Evaluar la infraestructura de red cableada e inalámbrica verificando su configuración, seguridad, disponibilidad y cumplimiento de buenas prácticas.

Telecomunicaciones

- Evaluar los medios de comunicación de datos, acceso a internet y dispositivos de conectividad para determinar su capacidad de soportar las operaciones del negocio.

4. ALCANCE DE LA AUDITORÍA (Redactar con enfoque evaluativo.)

Incluye:

- Equipos de cómputo
- Cableado
- Red LAN
- WiFi Router y switches
- Equipos de impresión
- Respaldo de información
- Seguridad física básica
- Acceso a internet

Excluye:

- Auditoría financiera
- Auditoría legal
- Bases de datos externas
- Servicios cloud externos

5. CRITERIOS DE AUDITORÍA (Normas y estándares aplicables)

5.1. Hardware

Norma / Marco	Justificación de su aplicación
ISO/IEC 27001	Permite evaluar la protección física de los activos tecnológicos y la implementación de controles que reduzcan riesgos sobre los equipos.
ISO/IEC 27002	Proporciona buenas prácticas para la gestión segura de activos tecnológicos y controles de protección física y ambiental.
ANSI/EIA 748	Permite verificar la adecuada administración y control de los activos tecnológicos durante su ciclo de vida.
ITIL	Facilita la evaluación de procesos relacionados con inventario, mantenimiento, soporte técnico y gestión de activos tecnológicos.
NOM-001	Permite verificar que las instalaciones eléctricas protejan adecuadamente los equipos tecnológicos frente a riesgos eléctricos.

5.2. Redes

Norma / Marco	Justificación de su aplicación
ISO/IEC 27033	Permite evaluar los controles de seguridad implementados para proteger la infraestructura de red y las comunicaciones.

IEEE 802	Establece las bases técnicas para la operación de redes locales y comunicaciones de datos.
802.3 Ethernet	Sirve para verificar el correcto funcionamiento y desempeño de las redes cableadas utilizadas por la organización.
802.11 WiFi	Permite evaluar la seguridad y disponibilidad de las redes inalámbricas utilizadas por la empresa.
TIA/EIA-568	Establece criterios para revisar la correcta instalación y organización del cableado estructurado.
TIA/EIA-569	Permite evaluar los espacios físicos y canalizaciones destinados a la infraestructura de telecomunicaciones.
TIA/EIA-606	Facilita la revisión de los procesos de identificación y etiquetado de componentes de red.
RFC 1918	Permite verificar el uso adecuado de direcciones IP privadas dentro de la infraestructura interna.
NIST Cybersecurity Framework	Proporciona lineamientos para identificar, proteger, detectar y responder a riesgos relacionados con la red.

5.3. Telecomunicaciones

Norma / Marco	Justificación de su aplicación
ITU-T	Establece recomendaciones internacionales para garantizar calidad, interoperabilidad y eficiencia en servicios de telecomunicaciones.

ISO/IEC 27001	Permite verificar controles de seguridad relacionados con la transmisión de información.
ISO/IEC 27002	Proporciona buenas prácticas para proteger la información durante los procesos de comunicación.
TIA-942	Permite evaluar aspectos relacionados con disponibilidad, redundancia y continuidad de servicios tecnológicos.
IEEE 802.1 / 802.3 / 802.11	Establecen criterios técnicos para evaluar el funcionamiento de las comunicaciones de red cableadas e inalámbricas.
ETSI (European Telecommunications Standards Institute)	Proporciona estándares técnicos internacionales aplicables a la calidad y seguridad de las telecomunicaciones.

6. IDENTIFICACIÓN DE RIESGOS DEL PROCESO

Riesgo identificado	Impacto en el negocio	Prioridad
Fallas eléctricas en equipos críticos	Interrupción operativa y daño de hardware	Alto
Ausencia o deficiencia de respaldos	Pérdida de información crítica	Alto
Acceso no autorizado a la red WiFi	Riesgo de intrusión y fuga de información	Alto

Equipos tecnológicos obsoletos	Disminución del rendimiento operativo	Medio
Cableado sin identificación adecuada	Incremento de tiempos de mantenimiento	Medio
Fallas del proveedor de internet	Interrupción de ventas y servicios administrativos	Alto
Ausencia de redundancia en comunicaciones	Afectación de la continuidad operativa	Medio

7. PROCEDIMIENTOS DE AUDITORÍA (Planeados)

No.	Procedimiento	Evidencia esperada	Norma relacionada
1	Verificación física del inventario de equipos tecnológicos	Inventario actualizado, fotografías y registros	ITIL, ISO 27002
2	Revisión del estado del cableado y dispositivos de red	Fotografías y observación directa	TIA/EIA-568, TIA/EIA-606
3	Evaluación de la seguridad de la red WiFi y acceso a internet	Configuraciones y capturas	ISO 27033, IEEE 802.11
4	Revisión de mecanismos de respaldo y recuperación	Registros y capturas de evidencia	ISO 27001
5	Evaluación de instalaciones eléctricas y protección de equipos	Fotografías y observación directa	NOM-001-SEDE

6	Entrevistas al personal responsable de TI	Formatos de entrevista y respuestas documentadas	ISO 27001, ITIL

8. PROGRAMA DE ACTIVIDADES

Actividad	**Fecha**	**Hora Inicio**	**Hora Final**	**Lugar**	**Responsable**	**Recursos**
Reunión inicial de la auditoría	03/06/2026	3:00	3:20	Oficina administrativa	Equipo auditor	Plan de auditoría, formatos de entrevista
Aplicación de entrevistas	03/06/2026	3:20	3:50	CompuMax	Entrevistador	Cuestionarios, libreta, grabadora
Inspección física de hardware	03/06/2026	3:50	4:00	Área técnica	Equipo auditor	Checklist de hardware, cámara fotográfica
Revisión de infraestructura de red	03/06/2026	4:00	4:20	Instalaciones	Equipo auditor	Checklist de redes, cámara fotográfica
Evaluación de telecomunicaciones y conectividad	03/06/2026	4:20	4:50	Instalaciones	Analista	Checklist de telecomunicaciones

Revisión documental de inventarios	03/06/2026	4:50	5:10	Oficina administrativa	Equipo auditor	Inventarios, bitácoras, documentos
Aplicación y validación de los checklists	03/06/2026	5:30	6:00	CompuMax	Equipo auditor	Checklists impresos o digitales
Registro y clasificación de hallazgos encontrados durante la auditoría	04/06/2026	9:00	12:30	Sala de trabajo	Equipo auditor	Evidencias recopiladas
Análisis de riesgos y evaluación de las normas aplicadas	05/06/2026	12:00	2:30	Sala de trabajo	Equipo auditor	Normas ISO, IEEE, TIA/EIA
Elaboración del informe final de auditoría	05/06/2026	1:30	6:00	Sala de trabajo	Equipo auditor	Computadora, evidencias y formatos

9. MECANISMO DE SUPERVISIÓN DE LA PLANEACIÓN

¿Cómo se verificará que el plan está correctamente diseñado?

	Revisión por auditor líder
	Validación contra normas seleccionadas
	Verificación de identificación de riesgos
	Aprobación formal

10. OBSERVACIONES GENERALES

Durante la ejecución de la auditoría se deberá mantener la objetividad, confidencialidad y ética profesional en el manejo de la información obtenida. Toda observación, hallazgo o recomendación deberá sustentarse mediante evidencia verificable, evitando conclusiones basadas en opiniones personales. Asimismo, cualquier limitación encontrada durante la auditoría deberá ser documentada para garantizar la transparencia y validez de los resultados obtenidos.

Elaboró	Revisó	Revisó
Auditor Líder	Auditado	Coordinador de Calidad

2) Trabajo de campo

Durante la visita realizada a CompuMax se aplicó una entrevista al encargado de ventas y soporte técnico, Uriel Hernández, quien proporcionó información sobre inventario, mantenimiento de equipos, protección eléctrica, red, internet, respaldos y administración básica de infraestructura.

La evidencia obtenida se basó en:

- Declaración del entrevistado.
- Fotografías del cuarto de cómputo.
- Fotografías de switch, router y equipo de cómputo.
- Observación directa limitada.
- Checklists





Entrevista

El objetivo de la entrevista fue obtener información sobre la gestión de activos tecnológicos, mantenimiento de hardware, administración de la infraestructura de red, mecanismos de respaldo, protección eléctrica y procedimientos operativos relacionados con la continuidad de los servicios tecnológicos.



Las preguntas realizadas fueron diseñadas tomando como referencia los checklist de auditoría de hardware, redes y telecomunicaciones previamente elaborados con base en normas internacionales como ISO/IEC 27001, ISO/IEC 27002, ISO/IEC 27033, ITIL, IEEE 802 y TIA/EIA.

Durante la entrevista se identificó que la empresa cuenta con un sistema de inventario que registra los productos y equipos mediante números de serie y códigos de barras, permitiendo controlar entradas, salidas, ventas, garantías y equipos en reparación. Asimismo, se indicó que el sistema actualiza automáticamente las existencias cuando se realiza una venta o cuando se registra una compra proveniente de proveedores.

Respecto al mantenimiento de equipos, el entrevistado indicó que las actividades de soporte técnico y reparación son realizadas internamente, atendiendo de manera continua los equipos que ingresan al área de servicio. También se informó que los equipos dañados generalmente son reparados en lugar de ser sustituidos y que los equipos considerados obsoletos suelen ser reacondicionados para prolongar su vida útil.

El apartado de infraestructura eléctrica, se informó que los equipos de trabajo cuentan con reguladores de voltaje y que el servidor principal se encuentra

protegido mediante un sistema UPS, debido a que almacena la base de datos utilizada por la organización.

Por otra parte, el funcionamiento de los sistemas depende directamente del servidor principal y de la conectividad de red interna. También se informó que la empresa utiliza servicios de internet proporcionados por Telmex y dispone de múltiples conexiones de red que permiten mantener la continuidad operativa en caso de fallas de alguno de los enlaces.



Respecto a la seguridad de la red inalámbrica, el entrevistado mencionó que las contraseñas son actualizadas periódicamente y que actualmente no existe una red independiente para invitados. Asimismo, se indicó que el acceso a la configuración del router es administrado por el encargado de la tienda y que el personal tiene conocimiento de las credenciales de acceso a la red para apoyar a clientes cuando es necesario.

Observación Directa

Durante el recorrido realizado en las instalaciones se observaron equipos de cómputo destinados a las actividades administrativas y operativas, dispositivos de red utilizados para la interconexión de sistemas, así como infraestructura básica para la prestación de servicios tecnológicos.



Se identificó la existencia de un área destinada a la operación de los equipos principales de red y cómputo, donde fue posible observar dispositivos de comunicación como router, switch y equipo de cómputo asociado a las operaciones de la empresa.

Asimismo, se verificó visualmente la presencia de reguladores eléctricos en diversos equipos de trabajo y se confirmó la existencia de un UPS destinado a la protección del servidor principal.

La observación también permitió constatar la existencia de infraestructura de cableado para la interconexión de equipos y dispositivos de red. Sin embargo, debido a restricciones de acceso y al alcance de la visita, no fue posible realizar inspecciones detalladas de configuraciones internas, diagramas de red, racks de comunicaciones o cuartos de telecomunicaciones especializados.

Revisión Documental

La revisión documental tuvo como objetivo verificar la existencia de registros, procedimientos y documentos que respaldaran los controles tecnológicos implementados por la organización.

Durante la entrevista se obtuvo información referente a la existencia de un sistema de inventario utilizado para el control de equipos, productos y activos tecnológicos. No obstante, durante la visita no fue posible acceder directamente a reportes, capturas o documentos impresos que permitieran validar completamente la información registrada en dicho sistema.

3) Aplicación de checklist

A. HARDWARE

La auditoría de hardware realizada en CompuMax permitió identificar que la empresa cuenta con controles básicos para la gestión de sus activos tecnológicos, como un sistema de inventario, identificación mediante números de serie, mantenimiento correctivo y protección eléctrica mediante reguladores y UPS para el servidor principal. Sin embargo, se detectaron áreas de mejora importantes relacionadas con la documentación formal de inventarios, planes de mantenimiento preventivo, políticas de ciclo de vida del hardware, registros de acceso físico y mecanismos de continuidad operativa.

INVENTARIO DE EQUIPOS

#	Aspecto	Evidencia requerida	Si	No	Parcial
1	¿Existe un inventario actualizado de todos los equipos de hardware (servidores, PCs, laptops, switches, routers, almacenamiento, periféricos críticos)?	Captura del inventario (Excel, CMDB, herramienta)			X
2	¿Cada activo de hardware tiene un identificador único (número de serie, código de activo) registrado en el inventario?	Foto de la etiqueta física + registro	X		

3	¿El inventario incluye ubicación física exacta (rack, oficina, sala, número de sitio) de cada equipo?	Plano o descripción de ubicación			X
4	¿Se registra el responsable o custodio de cada equipo de hardware?	Nombre, puesto, correo en inventario			X
5	¿El inventario se actualiza al menos cada 30 días o tras cualquier cambio (altas, bajas, movimientos)?	Bitácora de actualizaciones / fecha última modificación			X
6	¿Los equipos en préstamo o asignados temporalmente (préstamo interno, proyectos) están identificados en el inventario con fechas?	Registro de préstamo firmado	X		
7	¿Existe un inventario separado para equipos en reparación o en cuarentena?	Listado o etiqueta en sistema	X		
8	¿Los equipos de red (switches, routers, firewalls) tienen inventario con	Captura de configuración o tabla de direcciones		X	

	direcciones IP de gestión y MAC?				
9	¿El inventario incluye el estado operativo (operativo, con fallas, en garantía, fuera de uso) de cada activo?	Campo de estado en inventario			X
10	¿Se realiza conteo físico (toma de inventario) al menos una vez al año y se compara con el registro?	Acta de conteo físico firmada			X

ESTADO FÍSICO Y MANTENIMIENTO

#	Aspecto	Evidencia requerida	Si	No	Parcial
11	¿Los equipos se encuentran libres de polvo acumulado en ventilaciones, disipadores y puertos?	Foto del interior (si aplica) o exterior			X
12	¿Se realiza limpieza interna de equipos críticos (servidores, PCs) al menos cada 6 meses?	Registro de mantenimiento preventivo			X

13	¿Los discos duros no presentan ruidos anormales, errores SMART o indicadores de falla inminente?	Captura de herramienta de diagnóstico (CrystalDiskInfo, SMART)			X
14	¿Las fuentes de poder y ventiladores funcionan sin ruidos excesivos ni sobrecalentamiento?	Termografía o medición de temperatura	X		
15	¿Los gabinetes y carcasas no tienen golpes, grietas o partes rotas que expongan componentes internos?	Foto del estado físico			X
16	¿Los conectores, puertos y cables están en buen estado (sin corrosión, dobleces o peladuras)?	Inspección visual + foto			X

17	¿Existe un plan de mantenimiento preventivo documentado que incluya limpieza, calibración y revisión de componentes?	Documento del plan y calendario		X	
18	¿Se lleva un historial de mantenimientos correctivos (fallas, reparaciones, cambios de piezas) por equipo?	Bitácora o ticket de soporte			X
19	¿Los equipos críticos tienen indicadores de temperatura ambiente dentro del rango especificado por el fabricante (por ejemplo, 18-27°C)?	Registro de sensores o termómetro		X	
20	¿Se realizan pruebas de diagnóstico de hardware	Captura de resultados de prueba.			X

	(memoria, disco, placa base) después de cualquier reparación?				

CONDICIONES ELÉCTRICAS Y PROTECCIÓN

#	Aspecto	Evidencia requerida	Si	No	Parcial
21	¿Los equipos de cómputo y servidores están conectados a supresores de picos o UPS certificados?	Foto del modelo y certificación	X		
22	¿El sistema de tierra física del centro de cómputo cumple con la NOM-001-SEDE (resistencia a tierra < 10 ohmios)?	Reporte de medición de tierra (últimos 12 meses)		X	
23	¿Los UPS tienen baterías en buen estado (prueba de autonomía realizada en los últimos 6 meses)?	Reporte de prueba de autonomía		X	
24	¿Los circuitos eléctricos dedicados para equipos de TI tienen	Foto del tablero eléctrico etiquetado			X

	protección contra sobrecorriente (interruptores termomagnéticos adecuados)?				
25	¿Se realiza termografía de contactos y conexiones eléctricas en cuartos de servidores al menos cada 6 meses?	Reporte de termografía		X	
26	¿Los cables de poder están ordenados y no representan riesgos de tropiezo o daño por aplastamiento?	Foto del cableado			X
27	¿Los equipos sensibles cuentan con protección contra variaciones de voltaje (reguladores o UPS de doble conversión)?	Listado de equipos protegidos	X		
28	¿Existe un plan de respuesta ante cortes de energía prolongados que incluya apagado seguro de equipos críticos?	Documento de procedimiento + bitácora de simulacros		X	
29	¿Los contactos eléctricos en el área de	Reporte de verificación		X	

	TI tienen polaridad correcta y están libres de falsos contactos?	con probador de polaridad			
30	¿Los generadores de respaldo (si existen) se prueban semanalmente con carga?	Registro de pruebas de generador		X	

CICLO DE VIDA DEL HARDWARE

#	Aspecto	Evidencia requerida	Si	No	Parcial
31	¿Cada equipo tiene registrada su fecha de adquisición, proveedor y período de garantía?	Ficha de activo			X
32	¿Se ha definido una política de fin de vida útil (EOL) para cada tipo de hardware (por ejemplo, servidores 5 años, PCs 4 años)?	Documento de política de refresco		X	
33	¿Se lleva un registro de equipos que han superado su vida útil recomendada por el fabricante?	Listado de equipos antiguos			X
34	¿Los equipos fuera de	Copia del contrato o		X	

	garantía tienen un plan de soporte o contrato de mantenimiento vigente?	factura			
35	¿Existe un procedimiento formal para dar de baja un equipo de hardware?	Procedimiento documentado			X
36	¿Antes de la baja, se realiza un borrado seguro de datos (certificado de destrucción lógica o física)?	Certificado de borrado o destrucción		X	
37	¿Los discos duros retirados se destruyen físicamente o se entregan a un proveedor certificado?	Acta de destrucción + fotos		X	
38	¿Se actualiza el inventario inmediatamente después de dar de baja un equipo?	Fecha de baja en sistema			X
39	¿Los equipos reacondicionados o reutilizados internamente reciben una nueva etiqueta de activo y se registra su historial?	Registro de reasignación			X

40	¿Se notifica a seguridad de la información la baja de equipos que manejaron datos sensibles?	Correo o bitácora de notificación		X	

CONTROL DE ACCESO FÍSICO

#	Aspecto	Evidencia requerida	Si	No	Parcial
41	¿El centro de cómputo o sala de servidores tiene puerta con cerradura de alta seguridad o sistema de control de acceso (tarjeta, biometría)?	Foto del sistema de acceso			X
42	¿Existe un registro de entradas y salidas del área de hardware crítico (bitácora o log electrónico)?	Registro de accesos (últimos 3 meses)		X	
43	¿El acceso a áreas de hardware está restringido solo a personal autorizado (lista actualizada)?	Lista de personal autorizado firmada			X
44	¿Las visitas o personal externo son	Política de escolta + bitácora de visitas	X		

	acompañadas durante todo el tiempo en áreas de hardware?				
45	¿Los gabinetes o racks de servidores tienen llave o candado individual?	Foto del rack cerrado		X	
46	¿Existe monitoreo por CCTV en el área de hardware crítico, con retención de grabaciones mínimo 30 días?	Captura de vista de cámara + política de retención			X
47	¿Se realizan revisiones periódicas de los permisos de acceso físico (cada 3 meses)?	Acta de revisión de accesos		X	
48	¿Las estaciones de trabajo en áreas abiertas tienen mecanismo de bloqueo automático (pantalla con password) cuando el usuario se ausenta?	Prueba en campo + política		X	
49	¿Los equipos portátiles se guardan en armarios o gavetas con llave al término de la jornada?	Foto del armario cerrado			X

50	¿Se cuenta con alarma de intrusión o sensores de puerta en el centro de cómputo?	Certificado de instalación + prueba			X

ESPALDOS Y REDUNDANCIA DE EQUIPOS CRÍTICOS

#	Aspecto	Evidencia requerida	Si	No	Parcial
51	¿Los servidores críticos cuentan con fuente de poder redundante (redundancia 1+1 o N+1)?	Foto del servidor etiqueta de PSU dual		X	
52	¿Los switches y routers principales tienen fuente redundante o equipo de respaldo en caliente?	Listado de equipos con redundancia		X	
53	¿Existe un plan de respaldo de configuraciones de equipos de red y servidores (backup de configuración)?	Captura de repositorio de configuraciones		X	
54	¿Se realizan pruebas de restauración de configuraciones al menos cada 6 meses?	Reporte de prueba de restauración		X	
55	¿Los equipos de almacenamiento crítico (SAN, NAS) tienen discos en RAID o redundancia similar?	Captura de configuración RAID		X	

56	¿Existe un servidor o nodo de respaldo (clúster o réplica) para servicios esenciales?	Diagrama de alta disponibilidad		X	
57	¿Los respaldos de información se realizan según política (diario, semanal) y se almacenan fuera de sitio?	Log de respaldos + registro de almacenamiento externo		X	
58	¿Los equipos críticos cuentan con contrato de soporte con tiempo de respuesta garantizado (SLA) de 4 horas o menos?	Copia del SLA firmado		X	
59	¿Se tiene un plan de continuidad que incluya hardware alterno (sitio caliente o frío) en caso de falla mayor?	Plan de continuidad + inventario de sitio alterno		X	
60	¿Se realiza un simulacro anual de falla de equipo crítico (ej. falla de servidor principal) y se documenta la lección aprendida?	Acta de simulacro + métricas de tiempo de recuperación		X	

B. REDES

La evaluación de la infraestructura de red mostró que CompuMax dispone de una red funcional que soporta las operaciones de ventas, inventario y soporte técnico. Se identificó la existencia de dispositivos de red operativos y acceso a internet estable; sin embargo, no se encontraron evidencias suficientes sobre segmentación de red, documentación técnica, políticas de seguridad, monitoreo, gestión de vulnerabilidades ni controles avanzados de ciberseguridad. Asimismo, la red inalámbrica es compartida por empleados y clientes, lo que representa un riesgo de seguridad. En conclusión, el cumplimiento en redes es medio-bajo, debido a la falta de controles documentados y evidencias técnicas verificables.

ASPECTO	SI	PARCIAL	NO	EVIDENCIA	OBSERVACIONES
Sección 1: Seguridad en Redes (ISO/IEC 27033)					
1. Existe una política formal de seguridad de redes aprobada por la dirección, actualizada y comunicada al personal.			X	Política de seguridad de redes documentada y aprobada	No se localizó política formal de seguridad de red entregada.
2. La arquitectura de red está diseñada con controles de seguridad por capas (defensa en profundidad) y se encuentra documentada.		X		Diagramas de arquitectura de red y documentación técnica.	El sitio público opera como comercio en línea con HTTPS, Nginx y Next.js; no se proporcionó diagrama interno ni diseño por capas.
3. La red está segmentada en zonas (DMZ, LAN, WAN, WLAN) con controles de acceso entre segmentos mediante firewalls o ACLs.		X		Configuración de VLANs, ACLs, firewalls y diagramas de segmentación.	Para una PYME se presume separación básica por router.
4. Se utilizan firewalls, IDS/IPS y otros gateways de seguridad correctamente configurados y actualizados.		X		Capturas de configuración de firewall, IDS/IPS y registros de actualización.	No se presentó evidencia verificable.

5. Las conexiones VPN utilizan protocolos seguros (IPSec, TLS/SSL) con autenticación robusta y cifrado vigente.			X	Configuración VPN, certificados digitales y registros de conexiones seguras.	No se aportó evidencia de VPN corporativa, certificados de acceso remoto o registros de conexión.
6. Las redes convergentes (voz, datos, video) tienen controles de QoS y seguridad implementados.			X	Configuración QoS y documentación de redes convergentes.	No se aportó evidencia de QoS para voz/datos/video ni documentación de redes convergentes.
Sección 2: Infraestructura de Red Cableada (IEEE 802.3 / TIA/EIA-568)					
7. El cableado cumple con la categoría requerida (Cat5e, Cat6, Cat6A o superior) según las necesidades de velocidad y distancia. (IEEE 802.3 / TIA/EIA-568)		X		Especificaciones técnicas del cableado, facturas o etiquetas del cable.	No se permitió la inspección. Pero por el giro comercial es probable uso de cableado Ethernet, pero no hay especificaciones ni facturas del cableado interno.
8. Los segmentos de cable horizontal no exceden los 90 m de cable permanente (100 m máximo con patch cords). (TIA/EIA-568-C.2)		X		Planos de cableado y mediciones certificadas de longitud.	No se cuenta con planos ni mediciones certificadas; solo podría validarse por observación directa en sitio.
9. Los conectores y patch panels siguen la norma T568A o T568B de forma consistente en toda la instalación. (TIA/EIA-568)		X		Inspección física de conectores RJ45 y patch panels.	Cumplimiento de inspección física de conectores, patch cords y paneles.
10. Existen certificados de prueba (atenuación, NEXT, longitud) emitidos por equipo certificador para cada enlace. (TIA/EIA-568)			X	Reportes de certificación de cableado emitidos por equipo certificador.	No se presentaron certificados de prueba de enlaces de cableado emitidos por equipo certificador.
11. Las canalizaciones están instaladas conforme a TIA/EIA-569, separadas de cableado eléctrico de potencia. (TIA/EIA-569)		X		Inspección física de canalizaciones y planos de instalación.	Pendiente de verificar canalizaciones y separación de cableado eléctrico.
12. Los cuartos de telecomunicaciones cumplen dimensiones mínimas, control de acceso, temperatura y ventilación adecuados. (TIA/EIA-569)		X		Inspección del cuarto de telecomunicaciones, fotografías y registros ambientales.	Se evidencian registros ambientales en el cuarto de telecomunicaciones formal; existe área técnica básica por ser PYME.
13. El cuarto de equipos y el cuarto de entrada están designados, documentados y cumplen los		X		Planos de infraestructura, inventario y revisión física.	No se entregaron planos ni inventario formal del cuarto de equipos. Validar ubicación de router,

requisitos de espacio y energía. (TIA/EIA-569)					switch y entrada de servicio.
Sección 3: Redes Inalámbricas (IEEE 802.11 / ISO/IEC 27033)					
14. Los puntos de acceso utilizan WPA3 (o WPA2-Enterprise como mínimo). No se permite WEP ni WPA personal en redes corporativas. (IEEE 802.11)			X	Configuración de seguridad WiFi (WPA2/WPA3).	Se observó el uso de WPA2 Personal; no se evidenció WPA2 Enterprise.
15. Existen SSIDs separados para usuarios corporativos, invitados y dispositivos IoT, con VLANs distintas por segmento. (IEEE 802.11)			X	Configuración de SSID y VLANs en controladores o routers.	No se evidenciaron SSID separados para corporativo, invitados e IoT ni asociación con VLANs.
16. La red inalámbrica corporativa utiliza autenticación 802.1X con servidor RADIUS. (IEEE 802.11 / ISO 27033-5)			X	Configuración RADIUS y autenticación 802.1X.	No hay evidencia de autenticación 802.1X/RADIUS. Solo WPA2/WPA3 personal.
17. Se dispone de un sistema de gestión centralizada de APs con monitoreo de cobertura y clientes conectados. (IEEE 802.11)			X	Consola de administración de APs y reportes de monitoreo.	No se evidenció controlador centralizado de APs ni reportes de cobertura/clientes.
18. Existe proceso o herramienta para detectar y bloquear puntos de acceso no autorizados (Rogue AP). (ISO/IEC 27033)			X	Herramienta WIDS/WIPS o procedimientos para detección de APs no autorizados.	No se evidenció WIDS/WIPS ni procedimiento formal para detectar Rogue AP.
19. El firmware de los puntos de acceso está actualizado a la versión estable más reciente del fabricante. (IEEE 802.11)		X		Versiones de firmware instaladas y registros de actualización.	No se presentaron versiones ni bitácoras de actualización de firmware de APs/routers.
Sección 4: Etiquetado y Administración de Infraestructura (TIA/EIA-606)					
20. Todos los cables, paneles, puertos, equipos y canalizaciones tienen etiquetas únicas, legibles y conforme al estándar. (TIA/EIA-606-B)		X		Inspección física del etiquetado de cables y equipos.	Pendiente de inspección. Hay etiquetado básico, pero no se demostró cumplimiento TIA/EIA-606.
21. Existe documentación actualizada de la planta física: planos, diagramas de rack, registros de cable y asignación de puertos. (TIA/EIA-606-B)			X	Diagramas de red, planos de rack y documentación actualizada.	No se entregaron planos de rack, registros de cable o asignación de puertos actualizados.
22. Se mantienen registros de mantenimiento y log de cambios en		X		Bitácoras de mantenimien	Puede existir control informal de cambios/mantenimi

la infraestructura (Moves, Adds, Changes - MAC). (TIA/EIA-606-B)				to y control de cambios.	ento; no se entregaron bitácoras formales.
23. Se ha definido e implementado un nivel de administración (1 a 4) conforme al tamaño de la organización. (TIA/EIA-606-B)		X		Procedimientos de administración de infraestructura.	Administración probablemente básica acorde al tamaño de la empresa; requiere procedimiento mínimo documentado.
Sección 5: Direccionamiento IP (RFC 1918 / IEEE 802.3)					
24. La red interna utiliza únicamente rangos de direcciones privadas (10.x.x.x, 172.16-31.x.x, 192.168.x.x). (RFC 1918)		X		Configuración IP de dispositivos y esquema de direccionamiento.	No fue posible verificar el esquema de direccionamiento IP.
25. Existe diagrama de direccionamiento IP y tabla de subredes actualizada que refleja la topología real. (RFC 1918 / NIST)			X	Tabla de direccionamiento IP y diagrama lógico de red.	No se entregó diagrama de direccionamiento IP ni tabla de subredes actualizada.
26. Se utiliza herramienta o registro formal de gestión de direcciones IP (IPAM) para evitar conflictos. (RFC 1918)		X		Herramienta IPAM o registros manuales de asignación IP.	No se evidenció herramienta IPAM; podría manejarse por registro manual. Recomendada plantilla de asignación IP.
27. El NAT/PAT está correctamente configurado en el gateway de salida para traducir direcciones de forma controlada. (RFC 1918 / IEEE 802.3)		X		Configuración NAT/PAT del router o firewall.	NAT/PAT probablemente configurado en router/firewall de salida; requiere captura de configuración.
Sección 6: Gestión de Riesgos y Ciberseguridad en Redes (NIST CSF)					
28. Existe inventario completo y actualizado de todos los activos de red (switches, routers, firewalls, APs, servidores). (NIST CSF - Identify)			X	Inventario actualizado de activos de red.	No existe inventario completo y actualizado
29. El acceso a consola, SSH y panel de administración de dispositivos está restringido con contraseñas robustas y MFA. (NIST CSF - Protect)	X			Configuración de usuarios administrativos, políticas de contraseñas y MFA.	El login público usa Auth.js/cookies seguras y HTTPS; se evidenció MFA y política robusta para consolas/SSH internas.
30. Existe proceso formal de gestión de parches para firmware y software de todos los dispositivos, con		X		Cronograma y registros de actualización de	No hay cronograma formal de parches. Requiere registrar firmware de router/AP/switch y

periodicidad definida. (NIST CSF - Protect)				firmware/software.	fechas de actualización.
31. El tráfico sensible se transmite cifrado mediante TLS 1.2+, IPSec u otros protocolos seguros vigentes. (NIST CSF - Protect)	X			Capturas de configuración TLS, HTTPS, IPSec o VPN.	El sitio público utiliza HTTPS; se observó cabecera Nginx/Next.js en respuestas. Falta confirmar cifrado interno/VPN.
32. Se recopilan, almacenan y analizan logs de eventos de red en un sistema SIEM centralizado con retención adecuada. (NIST CSF - Detect)			X	Logs, servidor Syslog o plataforma SIEM.	No se evidenció SIEM, Syslog centralizado ni retención formal de logs de red.
33. Existe IDS/IPS activo, actualizado con firmas recientes, con alertas configuradas y procedimiento de respuesta definido. (NIST CSF - Detect)			X	Consola IDS/IPS, alertas y registros de eventos.	No se evidenció IDS/IPS activo ni procedimiento de alertamiento.
34. Existe plan de respuesta a incidentes de seguridad de red documentado, probado y conocido por el equipo de TI. (NIST CSF - Respond)			X	Plan de respuesta a incidentes y evidencia de simulacros.	No se aportó plan de respuesta a incidentes ni evidencias de simulacros.
35. Existe plan de continuidad que incluye recuperación de la conectividad de red con RTO y RPO definidos y probados. (NIST CSF - Recover)			X	Plan de continuidad del negocio y pruebas de recuperación.	No se evidenció plan de continuidad con RTO/RPO para conectividad de red.
36. Se realizan evaluaciones de riesgos de red (vulnerability assessment / pen testing) al menos una vez al año. (NIST CSF - Protect)		X		Reportes de análisis de vulnerabilidades o pruebas de penetración.	Se realizó revisión externa básica del sitio, pero no hay reporte formal anual de vulnerabilidades o pentest autorizado.

C. TELECOMUNICACIONES

CompuMax cuenta con servicios de conectividad que permiten mantener la operación diaria de la empresa, incluyendo acceso a internet y redundancia básica mediante múltiples enlaces de red. No obstante, no fue posible verificar aspectos fundamentales como planes de continuidad, monitoreo de red, documentación de topología, controles de acceso, QoS, gestión de incidentes y seguridad de las comunicaciones debido a la falta de evidencia documental y acceso a configuraciones. Aunque la infraestructura cumple adecuadamente con las necesidades operativas actuales, el nivel de cumplimiento se considera medio, presentando riesgos relacionados con seguridad, disponibilidad y administración formal de telecomunicaciones.

INFRAESTRUCTURA DE COMUNICACIÓN							
No.	**Norma / Estándar**	**Indicador de Verificación**	**Descripción / Criterio de Evaluación**	**Cumple Sí/No/Parcial**	**Nivel de Riesgo**	**Evidencia Requerida**	**Observaciones**
1	ISO/IEC 27001	Inventario de equipos de telecomunicaciones	Se cuenta con inventario actualizado de routers, switches y puntos de acceso.	**Parcial**	Medio	Inventario físico/digital	Existe un sistema de inventario, pero carece de registros técnicos detallados de red
2	TIA-942	Cableado estructurado etiquetado	El cableado se encuentra identificado y organizado adecuadamente.	**No**	Alto	Fotografías y diagramas	El cableado está organizado pero no cumple con el estándar de etiquetado TIA/EIA-606.
3	IEEE 802.3	Estado de switches y puertos	Los switches funcionan correctamente y sin fallas visibles.	**Si**	Medio	Capturas de configuración	Los dispositivos operan correctamente sin fallas visibles según observación directa.
4	TIA-942	Seguridad física del centro de datos	El cuarto de telecomunicaciones posee acceso restringido.	**No**	Alto	Fotografías y registros	El área técnica no posee controles de acceso restringido ni bitácoras de ingreso.
5	IEEE 802.3	Administración de puertos de red	Los puertos no utilizados permanecen deshabilitados.	**No**	Medio	Configuración switch	No se encontró evidencia de que los puertos no utilizados estén deshabilitados.

6	IEEE 802.11	Cobertura inalámbrica adecuada	La señal inalámbrica cubre las áreas requeridas.	**Si**	Medio	Mapas de cobertura	La señal es suficiente para las operaciones administrativas y de ventas.
7	IEEE 802.3	Velocidad de enlaces	Los enlaces cumplen con la velocidad requerida.	**Parcial**	Medio	Pruebas de velocidad	El servicio es estable para la operación, pero no se presentaron reportes formales de pruebas de velocidad.
8	TIA-942	Organización de racks	Los racks se encuentran ordenados	**Si**	Medio	Fotografías	Los equipos se encuentran ordenados físicamente.
9	IEEE 802.3	Documentación de topología	Existe documentación actualizada de la red.	**No**	Medio	Diagramas	Existe una ausencia total de diagramas físicos y lógicos de la red.
CALIDAD DEL SERVICIO (QoS)							
No.	**Norma / Estándar**	**Indicador de Verificación**	**Descripción / Criterio de Evaluación**	**Cumple Sí/No/Parcial**	**Nivel de Riesgo**	**Evidencia Requerida**	**Observaciones**
10	ITU-T	Calidad del servicio QoS	Existe priorización de tráfico para aplicaciones críticas.	**No**	Medio	Configuración QoS	No se aportó evidencia de priorización de tráfico para aplicaciones críticas.
11	ITU-T	Latencia de red controlada	La red mantiene tiempos de respuesta aceptables.	**Parcial**	Medio	Reportes de monitoreo	La red es funcional, pero no existen sistemas de monitoreo de latencia.

DISPONIBILIDAD Y CONTINUIDAD DEL SERVICIO							
No.	**Norma / Estándar**	**Indicador de Verificación**	**Descripción / Criterio de Evaluación**	**Cumple Sí/No/Parcial**	**Nivel de Riesgo**	**Evidencia Requerida**	**Observaciones**
12	TIA-942	Redundancia enlaces	Existen redundantes garantizar continuidad operativa.	**Parcial**	Alto	Diagramas y contratos	Existen múltiples enlaces, pero no hay pruebas documentadas de conmutación por error.
13	ETSI	Monitoreo de red	La infraestructura cuenta con monitoreo continuo de disponibilidad.	**No**	Medio	Reportes del sistema	No se detectaron herramientas de monitoreo continuo de disponibilidad.
14	ITU-T	Plan de continuidad del servicio	Existe un plan documentado ante fallas de telecomunicaciones.	**No**	Alto	Plan documentado	No existe un documento formal que detalle la respuesta ante fallas de telecomunicaciones.
15	ISO/IEC 27001	Respaldo de configuraciones	Se realizan respaldos periódicos de equipos de comunicación.	**No**	Alto	Archivos de respaldo	No hay evidencia de copias de seguridad de las configuraciones de routers o switches.
16	ITU-T	Disponibilidad del servicio de internet	El servicio de internet mantiene alta disponibilidad.	**Si**	Medio	SLA y monitoreo	El servicio provisto por Telmex mantiene la operatividad del negocio.
17	ETSI	Capacidad de crecimiento de red	La infraestructura permite expansión futura.	**Si**	Bajo	Plan de capacidad	La infraestructura actual permite expansión

							básica acorde al tamaño de la PYME.
SEGURIDAD EN TRANSMISIÓN DE DATOS							
No.	**Norma / Estándar**	**Indicador de Verificación**	**Descripción / Criterio de Evaluación**	**Cumple Sí/No/Parcial**	**Nivel de Riesgo**	**Evidencia Requerida**	**Observaciones**
19	ISO/IEC 27001	Política de seguridad de red documentada	Existe una política formal para la administración y seguridad de redes.	**No**	Alto	Documento oficial	No se localizó ninguna política formal aprobada por la dirección.
20	ISO/IEC 27002	Firewall configurado	El firewall cuenta con reglas de seguridad definidas y documentadas.	**No**	Alto	Capturas y políticas	Se detectó IDS/IPS básico, pero sin reglas de firewall definidas ni documentadas.
21	ISO/IEC 27002	Uso de protocolos seguros	Se utilizan HTTPS, SSH o VPN para transmisión segura de datos.	**Parcial**	Alto	Configuraciones	El sitio web usa HTTPS, pero no hay evidencia de VPN para acceso remoto seguro.
22	IEEE 802.11	Seguridad de red inalámbrica	La red WiFi utiliza mecanismos seguros de autenticación y cifrado.	**No**	Alto	Capturas WiFi	La red WiFi es compartida por empleados y clientes sin segmentación.
23	ISO/IEC 27001	Control de acceso administrativo	Solo personal autorizado puede administrar los dispositivos de red.	**Parcial**	Alto	Bitácoras y usuarios	El acceso es administrado por el encargado, pero las contraseñas son conocidas

							por el personal.
24	IEEE 802.1	Control de acceso a dispositivos	La red restringe el acceso de dispositivos no autorizados.	**No**	Alto	Configuraciones	No se aplican restricciones para dispositivos no autorizados en la red.
25	ISO/IEC 27002	Gestión de contraseñas	Las contraseñas cumplen políticas de complejidad y renovación.	**No**	Alto	Política de seguridad	Las claves WiFi se comparten indiscriminadamente con terceros.
26	ETSI	Gestión de incidentes	Existe un procedimiento para atención de incidentes de red.	**No**	Medio	Procedimientos	No existe un procedimiento formal para la atención de fallas de red.
27	ISO/IEC 27002	Registro de eventos de red	Los dispositivos generan y almacenan registros de eventos.	**No**	Alto	Logs del sistema	No se evidenció el uso de sistemas SIEM o servidores Syslog centralizados.
28	ISO/IEC 27002	Protección contra malware	Los servidores poseen protección antivirus actualizada.	**Si**	Alto	Consola antivirus	Se verificó la presencia de software antivirus actualizado en los equipos.
29	ISO/IEC 27001	Actualización de firmware	Los dispositivos de red cuentan con firmware actualizado.	**No**	Alto	Reporte de versiones	No se presentaron bitácoras de actualización de routers o puntos de acceso.
30	ETSI	Administración remota segura	La administración	**Parcial**	Alto	Configuración remota	El login público es

			remota utiliza conexiones seguras.				seguro, pero no se validó el acceso remoto administrativo interno.
31	ISO/IEC 27002	Protección contra intrusiones	Existen mecanismos de detección o prevención de intrusiones.	**No**	Alto	Capturas y alertas	No existe un procedimiento de respuesta ante alertas.
32	ISO/IEC 27001	Gestión de cuentas de usuario	Las cuentas inactivas son eliminadas o bloqueadas.	**Parcial**	Medio	Reportes de usuarios	Se realiza un control básico de accesos a sistemas administrativos.
33	ISO/IEC 27002	Cifrado de información transmitida	Los datos sensibles viajan cifrados en la red.	**Parcial**	Alto	Configuración SSL/VPN	Se usa TLS para el sitio público, pero el tráfico interno no está verificado.
REDUNDANCIA DE ENLACES							
No.	**Norma / Estándar**	**Indicador de Verificación**	**Descripción / Criterio de Evaluación**	**Cumple Sí/No/Parcial**	**Nivel de Riesgo**	**Evidencia Requerida**	**Observaciones**
34	TIA-942	Redundancia de enlaces	Existen enlaces redundantes para garantizar continuidad operativa.	**Parcial**	Alto	Diagramas y contratos	Operativa pero carente de documentación técnica y planes de prueba.
35	IEEE 802.1	Prevención de fallas de red	Existen mecanismos para evitar interrupciones por bucles o errores.	**No**	Alto	Configuración de red	No se aportó evidencia de configuraciones contra bucles o errores de capa 2.
DEPENDENCIA DE PROVEEDORES EXTERNOS							

No.	Norma / Estándar	Indicador de Verificación	Descripción / Criterio de Evaluación	Cumple Sí/No/Parcial	Nivel de Riesgo	Evidencia Requerida	Observaciones
36	IFT México	Cumplimiento regulatorio	Los servicios cumplen regulaciones nacionales vigentes.	Si	Alto	Licencias y contratos	opera con un proveedor, pero no se obtuvo evidencia documental
37	ITU-T	Gestión de proveedores	Existe control y evaluación de proveedores externos.	Si	Medio	Contratos y SLA	Existe un registro y contacto establecido con los proveedores externos.
PROTOCOLOS DE COMUNICACIÓN UTILIZADOS							
No.	**Norma / Estándar**	**Indicador de Verificación**	**Descripción / Criterio de Evaluación**	**Cumple Sí/No/Parcial**	**Nivel de Riesgo**	**Evidencia Requerida**	**Observaciones**
38	IEEE 802.1	Segmentación de red implementada	La red utiliza mecanismos de segmentación para separar el tráfico.	No	Alto	Configuración de red	No se detectó el uso de VLANs para separar tráfico administrativo de operativo.
39	ISO/IEC 27002	Uso de protocolos seguros	Se utilizan HTTPS, SSH o VPN para transmisión segura de datos.	Parcial	Alto	Configuraciones	Uso limitado a servicios web externos (HTTPS).
40	IEEE 802.1	Separación de zonas de red	Existen redes independientes para usuarios, invitados y servidores	No	Alto	Diagramas de red	Empleados, invitados y servidores comparten la misma zona de red.

4) Registro de hallazgos

Hallazgo 1. Ausencia de una red inalámbrica separada para invitados

Área evaluada: Redes

Hallazgo detectado:

Durante la entrevista realizada al encargado de ventas y soporte técnico se identificó que la empresa no cuenta con una red inalámbrica independiente para visitantes o clientes. La red WiFi utilizada dentro de la organización es compartida entre el personal y los usuarios externos que requieren acceso temporal a internet.

Evidencia:

Declaración del entrevistado indicando que no existe una red para invitados y que el acceso inalámbrico es general para todos los usuarios.

Norma o estándar relacionado:

- ISO/IEC 27033
- IEEE 802.11
- NIST Cybersecurity Framework

Nivel de riesgo: Alto

Impacto potencial:

La utilización de una red compartida incrementa la superficie de ataque y puede permitir accesos no autorizados a recursos internos de la organización, comprometiendo la confidencialidad, integridad y disponibilidad de la información.

Condición actual:

La empresa opera con una única red inalámbrica para personal y visitantes.

Condición ideal:

Implementar redes inalámbricas segmentadas mediante VLAN o SSID independientes para usuarios internos, invitados y dispositivos críticos.

Hallazgo 2. Gestión de contraseñas de acceso inalámbrico insuficiente

Área evaluada: Redes

Hallazgo detectado:

Se identificó que las credenciales de acceso a la red inalámbrica son conocidas por todo el personal de la empresa y pueden ser compartidas con clientes cuando estos requieren conectividad.

Evidencia:

Declaración del entrevistado indicando que todos los empleados conocen la contraseña y pueden proporcionarla a los clientes.

Norma o estándar relacionado:

- ISO/IEC 27001
- ISO/IEC 27002
- IEEE 802.11

Nivel de riesgo: Alto

Impacto potencial:

La difusión indiscriminada de credenciales dificulta la trazabilidad de accesos y aumenta el riesgo de conexión de dispositivos no autorizados a la red corporativa.

Condición actual:

La contraseña es compartida entre el personal y puede ser proporcionada a terceros.

Condición ideal:

Implementar políticas de control de acceso, autenticación diferenciada y mecanismos de renovación controlada de credenciales.

Hallazgo 3. Falta de documentación formal de la infraestructura de red

Área evaluada: Redes

Hallazgo detectado:

No se presentó evidencia documental relacionada con diagramas de red, topologías, direccionamiento IP, inventario detallado de dispositivos de red o documentación técnica de la infraestructura.

Evidencia:

Ausencia de diagramas, registros o documentación durante la auditoría.

Norma o estándar relacionado:

- TIA/EIA-606
- ISO/IEC 27033
- NIST Cybersecurity Framework



Nivel de riesgo: Medio

Impacto potencial:

La falta de documentación dificulta las actividades de mantenimiento, recuperación ante incidentes, identificación de fallas y administración de la infraestructura tecnológica.

Condición actual:

No existe evidencia verificable de documentación actualizada.

Condición ideal:

Mantener diagramas físicos y lógicos actualizados, así como registros de configuración y direccionamiento de red.

Hallazgo 4. Inexistencia de una política formal de renovación de hardware

Área evaluada: Hardware

Hallazgo detectado:

Se identificó que la empresa no cuenta con una política formal para la sustitución o renovación de equipos tecnológicos. Los equipos son conservados mientras continúen funcionando y, en caso necesario, son reacondicionados para prolongar su vida útil.

Evidencia:

Declaración del entrevistado indicando que existen equipos con más de quince años de operación.

Norma o estándar relacionado:

- ITIL
- ANSI/EIA-748
- ISO/IEC 27002

Nivel de riesgo: Medio

Impacto potencial:

El uso prolongado de equipos obsoletos puede generar fallas operativas, incompatibilidad tecnológica y reducción del rendimiento general de la infraestructura.

Condición actual:

Los equipos son utilizados hasta presentar fallas significativas.

Condición ideal:

Establecer políticas de ciclo de vida que definan criterios de actualización, reemplazo y retiro de equipos.

Hallazgo 5. Mantenimiento preventivo sin procedimiento documentado

Área evaluada: Hardware

Hallazgo detectado:

Aunque la empresa realiza actividades de soporte y mantenimiento de equipos de manera frecuente, no se evidenció la existencia de procedimientos documentados, calendarios formales ni registros estandarizados de mantenimiento preventivo.

Evidencia:

Declaración del entrevistado y ausencia de documentación formal.



Norma o estándar relacionado:

- ITIL
- ISO/IEC 27002

Nivel de riesgo: Medio

Impacto potencial:

La ausencia de procedimientos documentados dificulta la trazabilidad de actividades de mantenimiento y puede ocasionar inconsistencias en la atención de incidentes.

Condición actual:

El mantenimiento se realiza de manera operativa y reactiva.

Condición ideal:

Contar con procedimientos documentados y registros históricos de mantenimiento preventivo y correctivo.

Hallazgo 6. Dependencia de respaldos locales

Área evaluada: Hardware / Telecomunicaciones

Hallazgo detectado:

Los respaldos de información son realizados cada 24 horas mediante un disco duro conectado al servidor principal; sin embargo, no se presentó evidencia de almacenamiento externo o fuera del sitio.

Evidencia:

Declaración del entrevistado.

Norma o estándar relacionado:

- ISO/IEC 27001
- ISO/IEC 27002

Nivel de riesgo: Alto

Impacto potencial:

En caso de robo, incendio, inundación o daño físico del servidor, la información respaldada podría perderse simultáneamente.

Condición actual:

Los respaldos se almacenan localmente.

Condición ideal:

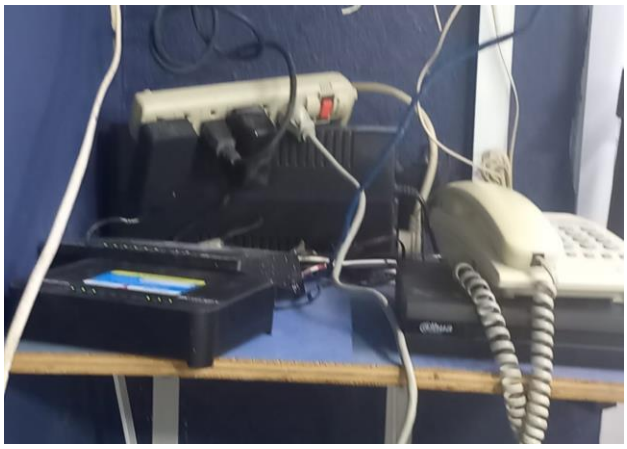
Implementar respaldos externos, almacenamiento en sitio alterno o soluciones de respaldo híbridas.

Hallazgo 7. Fortalecimiento parcial de la continuidad operativa mediante redundancia de enlaces

Área evaluada: Telecomunicaciones

Hallazgo detectado:

La empresa dispone de múltiples conexiones de red y tarjetas de red configuradas para mantener la conectividad cuando un enlace falla; sin embargo, no se presentó evidencia documental de pruebas de continuidad o procedimientos formalizados.



Norma o estándar relacionado:

- TIA-942
- ITU-T

Nivel de riesgo: Medio

Impacto potencial:

La ausencia de documentación y pruebas periódicas puede generar incertidumbre sobre la efectividad real de los mecanismos de redundancia.

Condición actual:

La redundancia existe de manera operativa según la información proporcionada.

Condición ideal:

Contar con procedimientos documentados, pruebas periódicas y registros de continuidad operativa.

Hallazgo 8. Protección eléctrica adecuada para el servidor principal

Área evaluada: Hardware

Hallazgo detectado:

Se verificó que el servidor principal se encuentra protegido mediante un sistema UPS destinado a mantener la operación ante fallas eléctricas de corta duración.

Evidencia:

Observación directa y declaración del entrevistado.

Norma o estándar relacionado:

- ISO/IEC 27001
- NOM-001-SEDE

Nivel de riesgo: Bajo

Impacto potencial:

La protección implementada reduce la probabilidad de pérdida de información y daños derivados de interrupciones eléctricas.

Condición actual:

El servidor dispone de UPS y los demás equipos utilizan reguladores.

Condición ideal:

Mantener programas de monitoreo y pruebas periódicas de autonomía para los sistemas UPS.



5) Análisis y recomendaciones

El análisis de los hallazgos obtenidos durante la auditoría se realizó considerando la evidencia recopilada mediante entrevistas, observación directa, revisión de la infraestructura disponible y aplicación parcial de los checklists de Hardware, Redes y Telecomunicaciones. Las recomendaciones emitidas se fundamentan en las normas ISO/IEC 27001, ISO/IEC 27002, ISO/IEC 27033, ITIL, TIA/EIA e IEEE aplicables a la infraestructura tecnológica auditada.

Hallazgo 1. Ausencia de una red inalámbrica separada para invitados

Análisis

Durante la auditoría se identificó que la empresa utiliza una única red inalámbrica para personal interno y visitantes. De acuerdo con ISO/IEC 27033 y IEEE 802.11, la segmentación de redes constituye un control fundamental para reducir riesgos de acceso no autorizado y limitar la exposición de recursos críticos.

Recomendación técnica

Implementar una red inalámbrica independiente para visitantes mediante la creación de un SSID exclusivo con restricciones de acceso a los recursos internos de la empresa.

Acción correctiva o preventiva

Configurar VLAN o redes separadas para usuarios internos y externos, estableciendo políticas de acceso diferenciadas.

Prioridad: Alta

Posible mejora a futuro

Implementar autenticación centralizada y segmentación lógica de la red para dispositivos administrativos, visitantes y equipos críticos.

Hallazgo 2. Gestión insuficiente de contraseñas de acceso inalámbrico

Análisis

Se observó que las credenciales de acceso a la red son compartidas entre el personal y pueden ser proporcionadas a clientes. Esta práctica incrementa el riesgo de accesos no autorizados y dificulta la trazabilidad de actividades realizadas en la red.

Recomendación técnica

Establecer una política formal de gestión de contraseñas que contemple complejidad, renovación periódica y control de acceso.

Acción correctiva o preventiva

Asignar credenciales diferenciadas para usuarios internos y visitantes, así como restringir la difusión de contraseñas corporativas.

Prioridad: Alta

Posible mejora a futuro

Implementar autenticación basada en usuarios individuales mediante WPA2/WPA3 Enterprise y servidor de autenticación.

Hallazgo 3. Falta de documentación formal de la infraestructura de red

Análisis

No se presentó evidencia de diagramas de red, inventarios técnicos, topologías ni registros actualizados de infraestructura. La documentación constituye un elemento esencial para la administración, mantenimiento y recuperación ante incidentes.

Recomendación técnica

Desarrollar y mantener documentación actualizada de la infraestructura tecnológica.

Acción correctiva o preventiva

Elaborar diagramas físicos y lógicos de red, inventarios de dispositivos y registros de configuraciones relevantes.

Prioridad: Media

Posible mejora a futuro

Implementar una plataforma centralizada de gestión documental para la infraestructura tecnológica.

Hallazgo 4. Ausencia de una política formal de renovación de hardware

Análisis

Se identificó que la empresa mantiene equipos en operación durante largos periodos mientras continúen funcionando. Aunque esta práctica optimiza costos, puede incrementar riesgos asociados a obsolescencia tecnológica y fallas de hardware.

Recomendación técnica

Definir una política de ciclo de vida para los activos tecnológicos considerando antigüedad, rendimiento y soporte del fabricante.

Acción correctiva o preventiva

Establecer criterios para renovación, actualización y retiro de equipos.

Prioridad: Media

Posible mejora a futuro

Implementar indicadores de desempeño que permitan anticipar la sustitución de activos críticos.

Hallazgo 5. Mantenimiento preventivo sin procedimientos documentados

Análisis

Aunque la empresa realiza mantenimiento técnico de manera frecuente, no se identificaron procedimientos documentados ni registros estandarizados de ejecución. Esto limita la trazabilidad de las actividades realizadas.

Recomendación técnica

Formalizar un programa de mantenimiento preventivo para equipos de cómputo, dispositivos de red y sistemas críticos.

Acción correctiva o preventiva

Elaborar procedimientos, formatos de registro y cronogramas de mantenimiento.

Prioridad: Media

Posible mejora a futuro

Implementar un sistema de gestión de tickets y mantenimiento basado en buenas prácticas ITIL.

Hallazgo 6. Dependencia de respaldos almacenados localmente

Análisis

Los respaldos son realizados cada 24 horas mediante un disco duro conectado al servidor principal. Sin embargo, no se identificó evidencia de almacenamiento externo o fuera de las instalaciones.

Recomendación técnica

Implementar una estrategia de respaldo que contemple almacenamiento externo y recuperación ante desastres.

Acción correctiva o preventiva

Mantener copias de seguridad en dispositivos externos o servicios especializados fuera del sitio principal.

Prioridad: Alta

Posible mejora a futuro

Adoptar una estrategia de respaldo 3-2-1 que contemple múltiples copias en diferentes medios y ubicaciones.

Hallazgo 7. Falta de documentación formal de continuidad de telecomunicaciones

Análisis

Aunque se indicó la existencia de enlaces redundantes y múltiples tarjetas de red, no se presentó evidencia documental de pruebas, procedimientos o planes de continuidad.

Recomendación técnica

Documentar formalmente los mecanismos de continuidad operativa relacionados con conectividad y telecomunicaciones.

Acción correctiva o preventiva

Elaborar procedimientos de contingencia y recuperación ante fallas de conectividad.

Prioridad: Media

Posible mejora a futuro

Realizar pruebas periódicas de continuidad y documentar los resultados obtenidos.

Hallazgo 8. Protección eléctrica implementada únicamente en equipos críticos

Análisis

Se verificó que el servidor principal cuenta con UPS, mientras que otros equipos utilizan reguladores eléctricos. Esta medida reduce riesgos, aunque podría fortalecerse mediante una protección más amplia de la infraestructura.

Recomendación técnica

Evaluar la incorporación de sistemas de respaldo energético adicionales para equipos de alta criticidad.

Acción correctiva o preventiva

Realizar pruebas periódicas de UPS y verificar la capacidad de autonomía requerida.

Prioridad: Baja

Posible mejora a futuro

Implementar monitoreo continuo del estado de UPS y sistemas de protección eléctrica.



6) Dictamen de auditoría

Como resultado de la auditoría realizada a la infraestructura tecnológica de CompuMax, mediante entrevistas al personal responsable, observación directa de las instalaciones, revisión de la infraestructura disponible y aplicación de los checklists de Hardware, Redes y Telecomunicaciones, se concluye que la empresa

dispone de una infraestructura tecnológica funcional y adecuada para soportar sus operaciones comerciales, administrativas y de soporte técnico.

Se identificó la existencia de controles operativos relacionados con inventario de activos, mantenimiento técnico, protección eléctrica del servidor principal, respaldos periódicos de información y mecanismos básicos de redundancia en la conectividad de red. Estos elementos contribuyen a la continuidad de las operaciones y al adecuado funcionamiento de los servicios tecnológicos utilizados por la organización.

Sin embargo, también se detectaron oportunidades de mejora relacionadas con la formalización de procedimientos, documentación de infraestructura, segmentación de redes, gestión de accesos, políticas de seguridad y continuidad operativa. Asimismo, algunas áreas no pudieron ser verificadas completamente debido a la ausencia de evidencia documental o restricciones de acceso a configuraciones internas y equipos críticos.

a. Opinión General del Estado de la Infraestructura Tecnológica

La infraestructura tecnológica de CompuMax presenta un estado operativo estable y funcional para el desarrollo de sus actividades diarias. Los equipos observados se encuentran en condiciones adecuadas de funcionamiento y existe personal con conocimientos técnicos para realizar actividades de soporte y mantenimiento.

No obstante, se observó que varios controles se encuentran implementados de manera práctica, pero no formalizada, lo que limita la capacidad de demostrar cumplimiento frente a estándares internacionales de seguridad y gestión tecnológica.

En términos generales, la infraestructura cumple con las necesidades actuales de la organización, aunque requiere fortalecer aspectos relacionados con seguridad, documentación y administración de riesgos tecnológicos.

b. Nivel de Cumplimiento Global

Área	Nivel de Cumplimiento
Hardware	Medio - Alto
Redes	Medio
Telecomunicaciones	Medio
Cumplimiento Global	Medio

El nivel de cumplimiento global se considera MEDIO, debido a que la empresa cuenta con controles tecnológicos básicos y mecanismos operativos funcionales; sin embargo, se identificaron deficiencias relacionadas con documentación, políticas formales, segmentación de red, gestión de accesos y evidencia verificable de diversos controles.

c. Principales Riesgos Detectados

Riesgo 1. Acceso no autorizado a la red inalámbrica

La inexistencia de una red independiente para invitados y el uso compartido de contraseñas incrementan el riesgo de accesos no autorizados a recursos corporativos.

Nivel de riesgo: Alto

Riesgo 2. Dependencia de respaldos almacenados localmente

Los respaldos se realizan periódicamente; sin embargo, no se evidenció almacenamiento externo o fuera del sitio.

Nivel de riesgo: Alto

Riesgo 3. Falta de documentación de infraestructura tecnológica

La ausencia de diagramas de red, procedimientos documentados y registros técnicos dificulta la administración y recuperación ante incidentes.

Nivel de riesgo: Medio

Riesgo 4. Ausencia de políticas formales de renovación tecnológica

La permanencia prolongada de equipos puede generar problemas de compatibilidad, rendimiento y disponibilidad.

Nivel de riesgo: Medio

Riesgo 5. Falta de planes documentados de continuidad operativa

No se presentó evidencia formal de procedimientos para recuperación ante fallas de telecomunicaciones o infraestructura tecnológica.

Nivel de riesgo: Medio

d. Fortalezas del Sistema Auditado

Durante la auditoría se identificaron los siguientes aspectos positivos:

- Administración de productos y equipos.
- Registro de números de serie para identificación de activos.
- Realización de respaldos periódicos de información.
- Protección eléctrica mediante UPS para el servidor principal.
- Uso de reguladores en estaciones de trabajo.
- Personal técnico capacitado para actividades de soporte y mantenimiento.
- Disponibilidad de enlaces de red redundantes para mantener la conectividad.
- Infraestructura tecnológica funcional para las operaciones actuales de la empresa.
- Control básico sobre los activos tecnológicos y procesos de soporte técnico.

e. Recomendaciones Estratégicas

1. Fortalecer la seguridad de la red inalámbrica

Implementar redes separadas para usuarios internos y visitantes mediante mecanismos de segmentación y control de acceso.

2. Formalizar la documentación tecnológica

Desarrollar y mantener actualizados:

- Inventarios tecnológicos.
- Diagramas físicos y lógicos de red.
- Procedimientos de mantenimiento.
- Procedimientos de respaldo.
- Planes de continuidad operativa.

3. Implementar políticas de gestión de activos

Establecer lineamientos para:

- Renovación tecnológica.
- Reemplazo de equipos.
- Baja de activos.
- Reutilización segura de hardware.

4. Mejorar la estrategia de respaldos

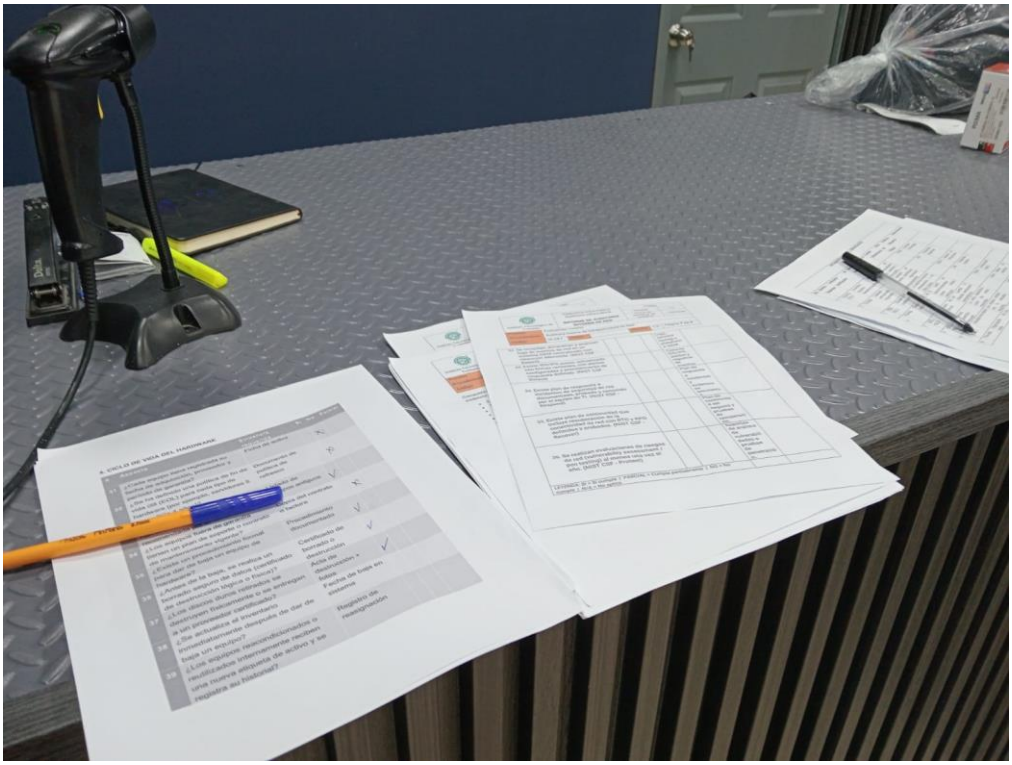
Adoptar mecanismos de almacenamiento externo o fuera del sitio para garantizar la recuperación de información ante incidentes mayores.

5. Incrementar el nivel de madurez en seguridad

Alinear gradualmente los controles tecnológicos a las recomendaciones establecidas en:

- ISO/IEC 27001
- ISO/IEC 27002
- ISO/IEC 27033
- ITIL
- NIST Cybersecurity Framework

7) ANEXOS

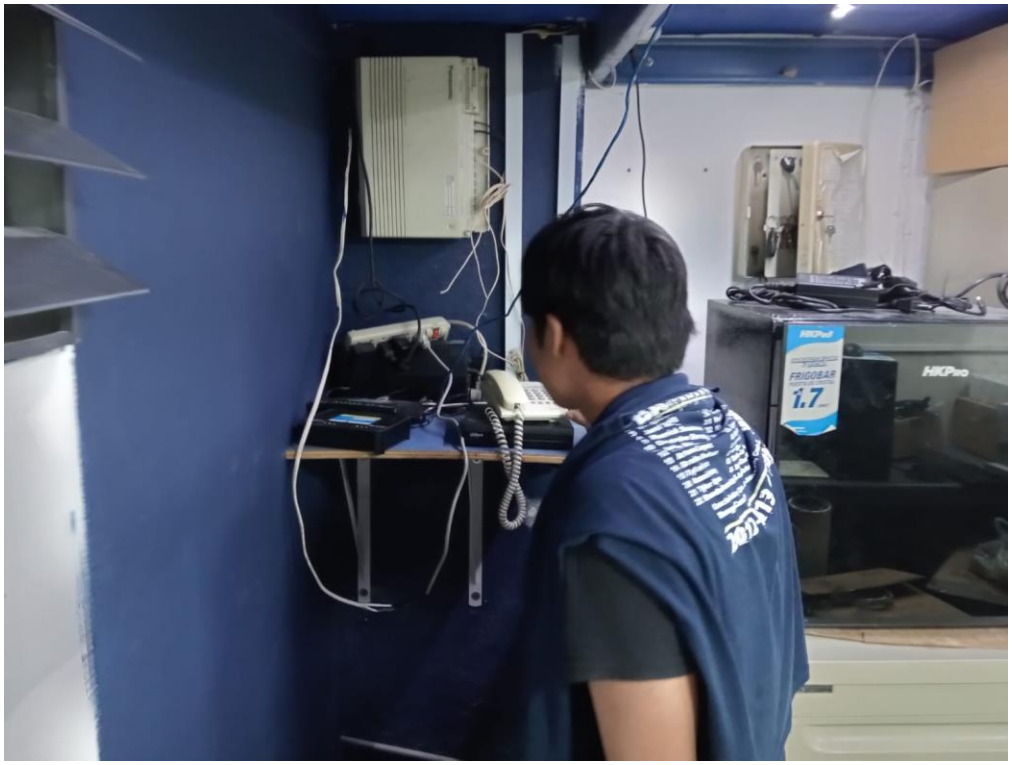







TEKNO-STEP


SanDisk
Lenovo
brother


FRIGOBAR
1.7



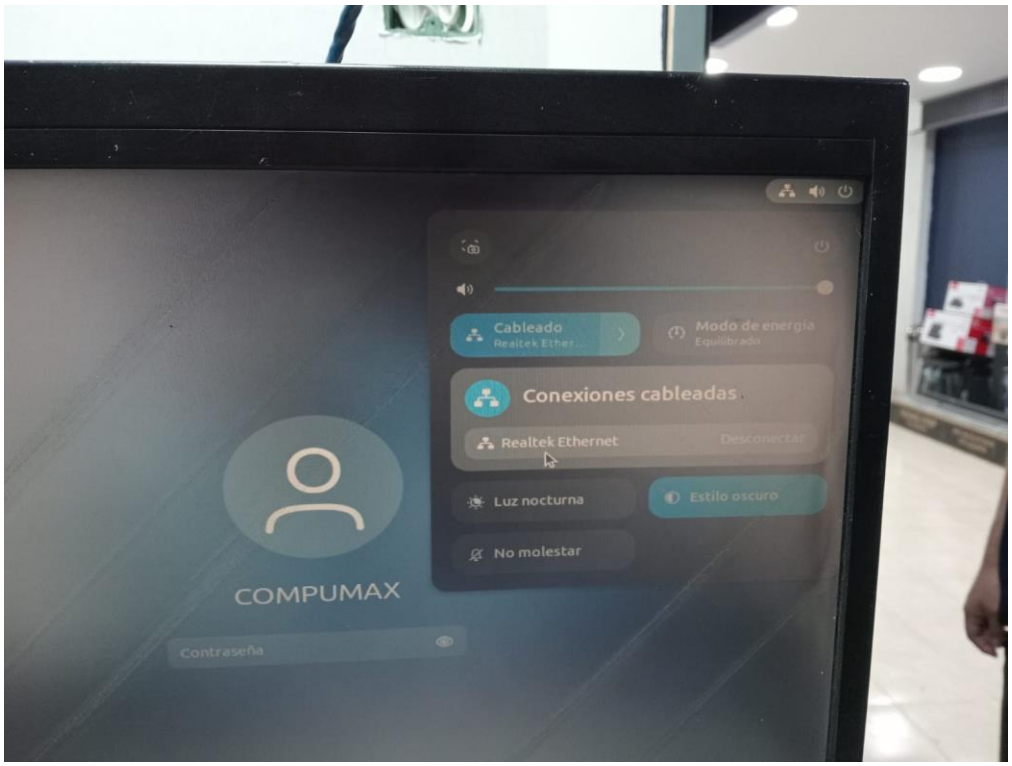




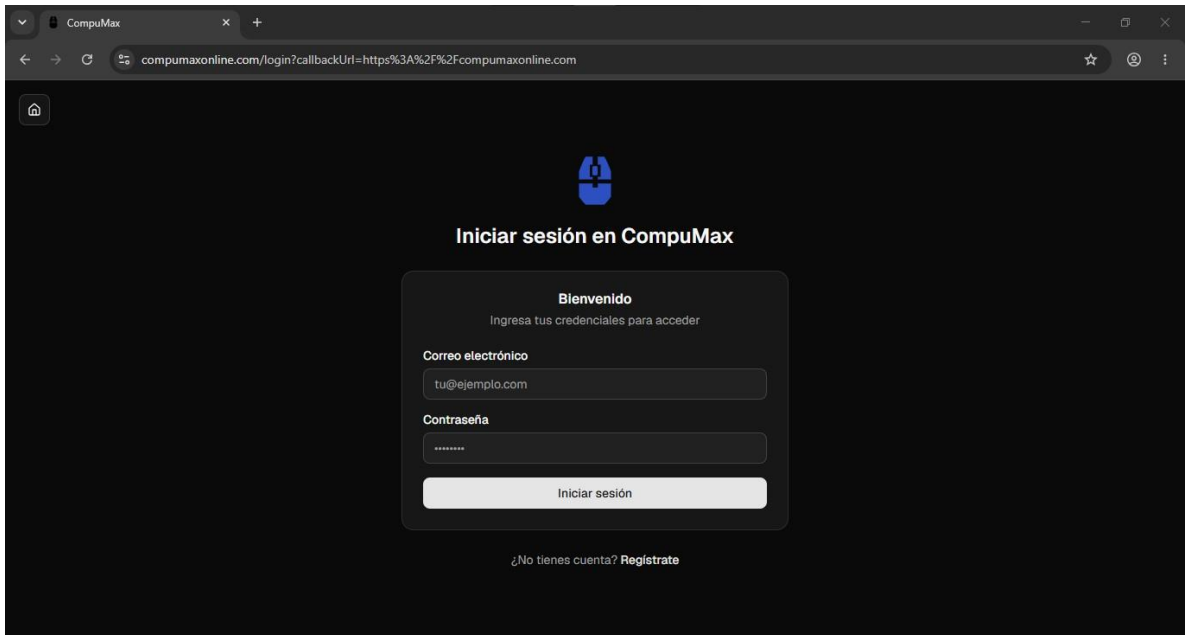

Cajon de dinero

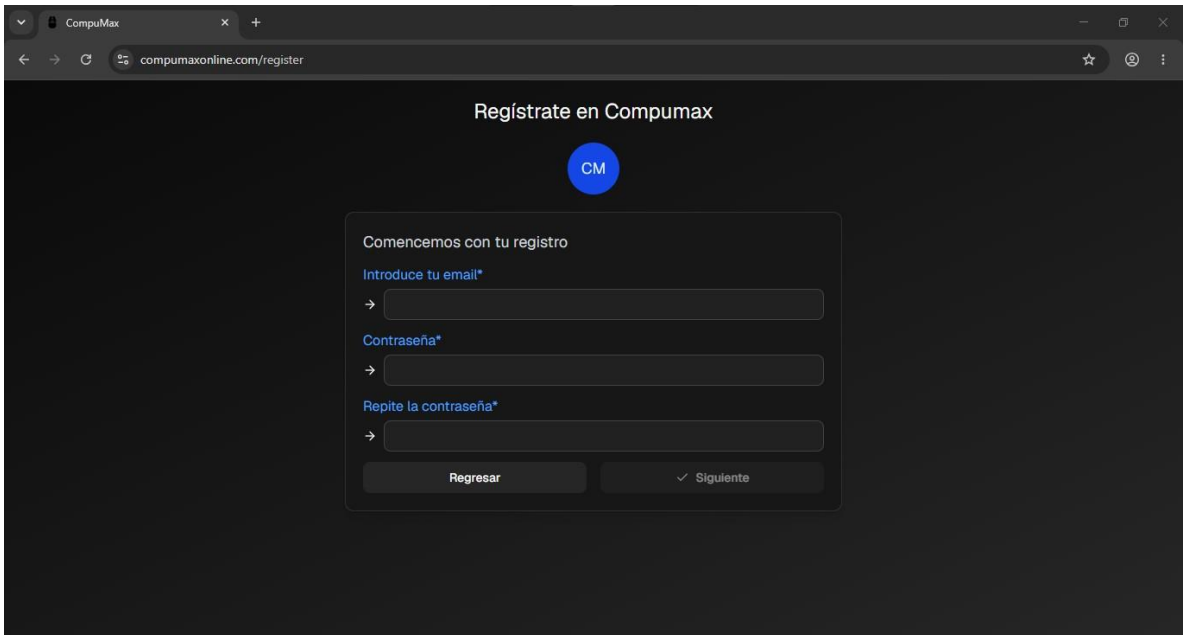


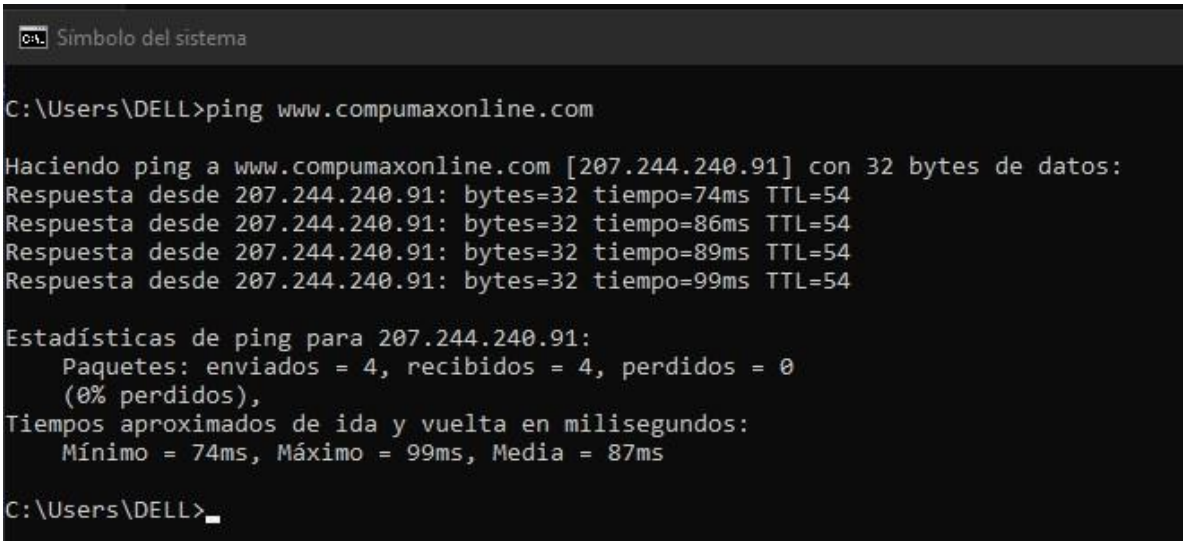

ACTECK
ACTECK
Performance II
40"

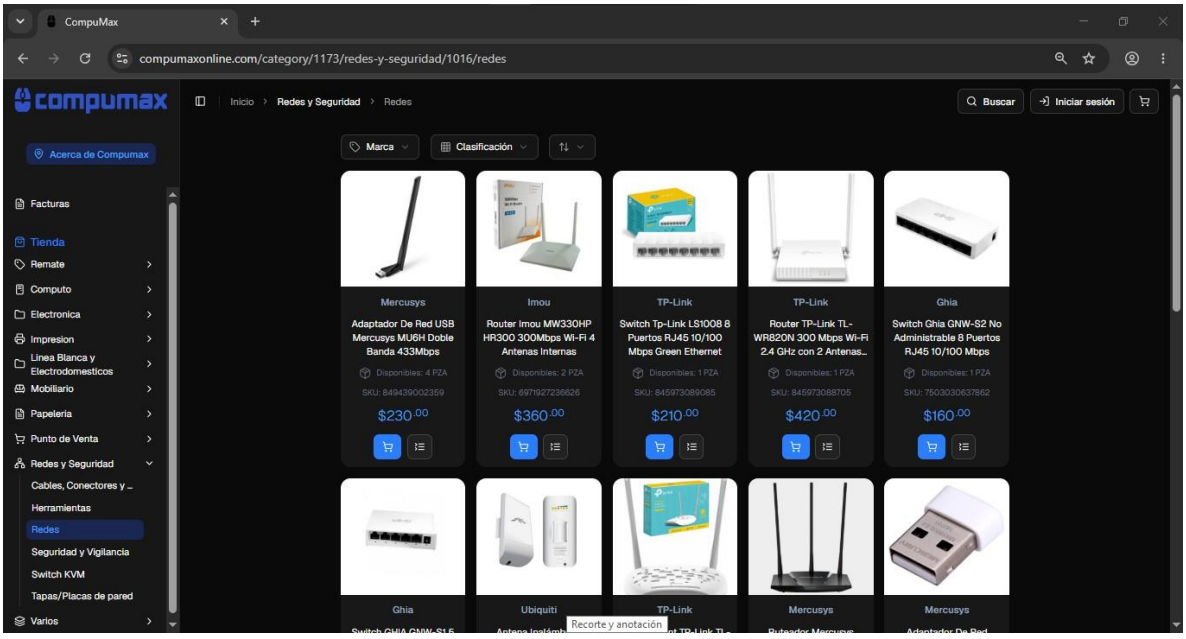

Cableado
Realtek Ether...
Modo de energía
Equilibrado
Conexiones cableadas
Realtek Ethernet
Desconectar
Luz nocturna
Estilo oscuro
No molestar
COMPUMAX
Contraseña


COMPUMAX
SOYO


CompuMax
compumaxonline.com/login?callbackUrl=https%3A%2F%2Fcompumaxonline.com
Iniciar sesión en CompuMax
Bienvenido
Ingresa tus credenciales para acceder
Correo electrónico
tu@ejemplo.com
Contraseña
Iniciar sesión
¿No tienes cuenta? Regístrate


CompuMax
compumaxonline.com/register
Regístrate en Compumax
CM
Comencemos con tu registro
Introduce tu email*
Contraseña*
Repite la contraseña*
Regresar
Siguiente


Símbolo del sistema
C:\Users\DELL>ping www.compumaxonline.com
Haciendo ping a www.compumaxonline.com [207.244.240.91] con 32 bytes de datos:
Respuesta desde 207.244.240.91: bytes=32 tiempo=74ms TTL=54
Respuesta desde 207.244.240.91: bytes=32 tiempo=86ms TTL=54
Respuesta desde 207.244.240.91: bytes=32 tiempo=89ms TTL=54
Respuesta desde 207.244.240.91: bytes=32 tiempo=99ms TTL=54
Estadísticas de ping para 207.244.240.91:
Paquetes: enviados = 4, recibidos = 4, perdidos = 0
(0% perdidos),
Tiempos aproximados de ida y vuelta en milisegundos:
Mínimo = 74ms, Máximo = 99ms, Media = 87ms
C:\Users\DELL>


CompuMax
compumaxonline.com/category/1173/redes-y-seguridad/1016/redes
compumax
Inicio
Redes y Seguridad
Redes
Buscar
Iniciar sesión
Acerca de Compumax
Facturas
Tienda
Remate
Computo
Electronica
Impresion
Linea Blanca y Electrodomesticos
Mobiliario
Papeleria
Punto de Venta
Redes y Seguridad
Cables, Conectores y ...
Herramientas
Redes
Seguridad y Vigilancia
Switch KVM
Tapas/Placas de pared
Varios
Marca
Clasificación
Mercusys
Adaptador De Red USB Mercusys MU6H Doble Banda 433Mbps
$230.00
Imou
Router Imou MW330HP HR300 300Mbps Wi-Fi 4 Antenas Internas
$360.00
TP-Link
Switch Tp-Link LS1008 8 Puertos RJ45 10/100 Mbps Green Ethernet
$210.00
TP-Link
Router TP-Link TL-WR820N 300 Mbps Wi-Fi 2.4 GHz con 2 Antenas...
$420.00
Ghia
Switch Ghia GNW-S2 No Administrable 8 Puertos RJ45 10/100 Mbps
$160.00
Ghia
Ubiquiti
TP-Link
Mercusys
Mercusys
Recorte y anotación


x20
HP ProLiant ML110 G6
HANDLE WITH CARE
MANIPULEZ AVEC SOIN
MANEJESE CON CUIDADO
MANUSEAR COM CUIDADO

